PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Lexique et fondamentaux de la cybersécurité

03-40 ANSSI - CyberDico Le lexique de la cybersécurité — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le cyberespace est l'espace de communication formé par l'interconnexion mondiale des équipements numériques.
2. L'endiguement regroupe les actions limitant l'ampleur d'un incident au début de la crise.
3. L'homologation de sécurité est la décision administrative autorisant l'exploitation d'un système d'information.

Concepts et mécanismes de base

Notion	À retenir
Définitions et Principes	La **cybersécurité** est l'état permettant de résister aux événements du cyberespace ; 3 piliers : **confidentialité**, **intégrité**, **disponibilité**. La **SSI** inclut les moyens techniques et non techniques. Le **cœur de confiance** : partie dont la compromission entraîne celle du **SI**.
Authentification et Cryptographie	**Authentification forte** (ex: **défi-réponse**) ; **hachage** à sens unique ; **IGC/PKI** pour clés et certificats ; **chiffrement** → **cryptogramme** illisible sans la clé ; **post-quantique** : résister aux futurs ordinateurs quantiques.

Panorama des menaces

Notion	À retenir
Typologie des Cyberattaques	**DoS/DDoS** (saturation ressources), **Man-in-the-middle** (interception/manipulation), **Canal auxiliaire** (signaux physiques), **Injection SQL** (code en base de données), **CSRF** (requêtes illégitimes).
Logiciels Malveillants	**Virus** (infecte fichiers), **Ver** (autonome/réseau), **Cheval de Troie** (masqué), **Rançongiciel** (chiffre/rançon), **Spyware** (collecte), **Cryptomineur** (ressources), **Bombe logique** (conditions).
Ingénierie Sociale et Fraude	**Phishing** (courriel), **Spearphishing** (ciblé), **Arnaque au président/FOVI** (virement), **Quishing** (code QR), **Usurpation carte SIM** (contourne double authentification).

Réseaux et Failles

Notion	À retenir
Réseaux et Protocoles	**DNS** : traduit noms de domaine en **adresses IP**. Risques : **usurpation DNS** (fausses réponses) ou **DNS pharming** (modification de serveur). **VPN** : tunnel sécurisé. **VoIP** : voix via **TCP/IP**.
Failles et Exploitation	**Zero-day** : vulnérabilité sans **correctif**. **N-day** : correctif existant non déployé. **Exploit** : programme d'utilisation. **Débordement de tampon** : écriture hors zone mémoire. **Élévation de privilège** : droits supérieurs obtenus.

Gouvernance, Détection et Défense

Notion	À retenir
Gestion des Risques	L'analyse évalue les menaces. Références : **EBIOS Risk Manager**, **RGPD** (données personnelles), directive **NIS**, **OIV** (survie nation) et **OSE** (services critiques).
Détection et Crise	Détection par **supervision**. Incident = compromission **disponibilité**, **intégrité** ou **confidentialité**. Réponse via **CERT/CSIRT**, **PCA** (mode dégradé), **PRA** (activités normales) et **remédiation**.
Organisation Défense	L'**ANSSI** est l'autorité nationale. La **cyberdéfense** est technique et non technique. Séparation **défense/offensive**. Prestataires : **PASSI** (audit) et **PDIS** (détection). **Visa de sécurité** = solutions fiables.

Pièges et confusions

- ⚠ Confondre identification (dire qui on est) et authentification (prouver qui on est)
- ⚠ Oublier qu'une alerte malveillante (swatting) peut provoquer une intervention inutile des forces de police.
- ⚠ Oublier que le débridage ou jailbreak expose l'appareil à des risques accrus
- ⚠ Confondre cybercriminalité (profit ou délit) et cyberdéfense (intérêts vitaux de l'État)
- ⚠ Confondre les indicateurs de compromission (IOC, marqueurs techniques caractérisant une attaque) avec les vulnérabilités elles-mêmes.

Sigles et définitions

Blockchain	registre de comptes numériques sécurisé par cryptographie et sans intermédiaire
Botnet	réseau de machines zombies utilisé à des fins malveillantes
BYOD	utilisation professionnelle d'équipements personnels
Rootkit	logiciel furtif donnant des droits d'administrateur à un tiers non autorisé
Shadow IT	systèmes informatiques déployés sans l'approbation de la direction informatique
Typosquatting	exploitation des fautes de frappe pour diriger vers des sites malveillants

Auto-test

1. Qu'est-ce qu'un bootkit ?
2. Quelle est la définition du cybersquating ?
3. Que permet de faire un keylogger ?
4. Qu'est-ce que la levée de doute ?
5. À quoi sert un pare-feu ?

Réponses : **1.** un code malveillant infectant le processus de démarrage · **2.** l'enregistrement abusif de noms de domaine pour bloquer leur attribution légitime · **3.** enregistrer les frappes au clavier pour voler des informations · **4.** vérifier si un événement est un incident réel ou un faux positif · **5.** protéger un ordinateur ou un réseau en filtrant les connexions

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.